

Техника AS-REQroasting в Kerberos: Глубокий технический разбор и практическое руководство

 redsec.by/article/tehnika-as-reqroasting-v-kerberos-glubokij-tehnicheskij-razbor-i-prakticheskoe-rukovodstvo

Red Teams | 7 апреля 2026



Введение: Эволюция атак на инфраструктуру Kerberos

В современной практике оценки защищенности корпоративных сетей (Red Teaming) атаки на протокол Kerberos занимают центральное место. Большинство специалистов хорошо знакомы с техниками Kerberoasting и AS-REP roasting, которые стали индустриальным стандартом для компрометации учетных записей Active Directory. Однако по мере повышения уровня зрелости IT-инфраструктур и повсеместного внедрения базовых политик безопасности (таких как обязательное включение преаутентификации), классический AS-REP roasting становится все менее применимым.

В этом контексте на первый план выходит **AS-REQroasting** (также известная как ASREQroast) — техника извлечения криптографического материала для офлайн-взлома пароля непосредственно из легитимного сообщения Kerberos AS-REQ. В отличие от своего "младшего брата" AS-REP roasting, данная атака не требует наличия мисконфигураций в Active Directory (например, флага DONT_REQ_PREAUTH). Она базируется на классическом перехвате трафика (Man-in-the-Middle) и позволяет извлечь зашифрованную временную метку, защищенную ключом, производным от пароля пользователя.

Данный whitepaper представляет собой исчерпывающее руководство по архитектуре, криптографии, практической эксплуатации и методам защиты от AS-REQroasting в реалиях 2024–2026 годов.

Базовая механика Kerberos и роль AS-REQ/AS-REP

Для глубокого понимания вектора атаки необходимо детально разобрать начальную фазу аутентификации Kerberos в домене Active Directory. Процесс получения первичного билета (Ticket Granting Ticket, TGT) состоит из обмена сообщениями между клиентом и сервисом аутентификации (Authentication Service, AS) на стороне Key Distribution Center (KDC).

1. **Генерация временной метки:** Клиент формирует текущую временную метку (timestamp), чтобы предотвратить атаки повторного воспроизведения (replay attacks).
2. **Шифрование (Преаутентификация):** Клиент шифрует эту метку симметричным ключом, который генерируется на основе его пароля (в AD это обычно NT-хэш или ключи AES). Результат помещается в структуру PA-ENC-TIMESTAMP.
3. **Отправка AS-REQ:** Клиент отправляет запрос KRB_AS_REQ на KDC.
4. **Валидация на стороне KDC:** Контроллер домена извлекает хэш пароля пользователя из базы NTDS.dit, вычисляет ключ и пытается расшифровать PA-ENC-TIMESTAMP. Если расшифрованное время находится в пределах допустимого окна (по умолчанию 5 минут в AD), преаутентификация считается успешной.
5. **Ответ AS-REP:** KDC формирует KRB_AS_REP, содержащий TGT и сессионный ключ, зашифрованный ключом пользователя.

Важно: Смысл преаутентификации заключается в том, чтобы KDC не выдавал зашифрованный материал (AS-REP) до тех пор, пока клиент криптографически не докажет знание своего пароля. Однако сам процесс "доказательства" (отправка зашифрованной метки в AS-REQ) создает артефакт, уязвимый для офлайн-перебора, если он будет перехвачен третьей стороной.

Концептуальная модель AS-REQroasting

AS-REQroasting — это техника класса "credential dumping из сетевого трафика" (plaintext protocol credential dumping). Злоумышленник, находясь в позиции MITM в локальной сети, пассивно или активно перехватывает пакеты KRB_AS_REQ.

Поскольку клиент *обязан* отправить временную метку, зашифрованную своим секретом, перехваченный пакет содержит готовую криптограмму. Атакующему остается лишь извлечь этот блок данных и применить к нему атаку по словарю или brute-force на высокопроизводительных GPU-кластерах. Успешный взлом дает злоумышленнику plaintext-пароль пользователя, открывая пути для интерактивного

входа (RDP, WinRM, VPN) и дальнейшего горизонтального перемещения (Lateral Movement).

Сравнительный анализ: AS-REQroasting против AS-REP roasting

Несмотря на схожесть названий, эти техники кардинально различаются по своим предпосылкам, точкам приложения усилий и требованиям к инфраструктуре.

Признак	AS-REQroasting	AS-REP roasting (T1558.004)
Точка атаки (Артефакт)	Перехваченный запрос клиента AS-REQ (поле PA-ENC-TIMESTAMP).	Ответ сервера AS-REP (зашифрованная часть билета), возвращенный KDC.
Не требуется. Работает при стандартной, корректно настроенной преаутентификации.	Требуется. У целевого аккаунта должен быть установлен флаг <i>"Do not require Kerberos preauthentication"</i> (UAC: 4194304).	
Вектор доступа	Сетевой перехват (MITM, ARP/DHCP Spoofing) между клиентом и KDC.	Прямой сетевой доступ к порту 88 (KDC). Атакующий сам генерирует запросы.
Классификация угрозы	Сбор учетных данных из сетевого трафика.	Злоупотребление механизмами Kerberos (Steal or Forge Kerberos Tickets).
Типичный инструментарий	PCredz, Wireshark, tshark, Bettercap, mitm6, Responder.	Rubeus (asreproast), Impacket (GetNPUsers.py), Kerbrute.

Риски: AS-REQroasting представляет скрытую угрозу. В отличие от AS-REP roasting, который генерирует аномальное количество запросов к KDC и легко детектируется SIEM-системами (Event ID 4768 с Pre-Auth Type 0), AS-REQroasting происходит на

сетевом уровне. KDC видит абсолютно легитимный процесс входа пользователя в систему.

Криптографический фундамент: Структура AS-REQ и типы шифрования

ASN.1 структура пакета

Протокол Kerberos использует нотацию ASN.1 (Abstract Syntax Notation One) и правила кодирования DER для формирования пакетов. Понимание этой структуры критично для написания собственных парсеров или настройки фильтров в снифферах.

Структура запроса KRB_AS_REQ выглядит следующим образом:

```
AS-REQ ::= [APPLICATION 10] KDC-REQ
KDC-REQ ::= SEQUENCE {
    pvno           [1] INTEGER (5),
    msg-type       [2] INTEGER (10),
    padata         [3] SEQUENCE OF PA-DATA OPTIONAL, -- Здесь находится преаутентиф
    req-body[4] KDC-REQ-BODY
}
PA-DATA ::= SEQUENCE {
    padata-type     [1] Int32,
    padata-value    [2] OCTET STRING
}
```

Когда преаутентификация включена, поле `padata-type` принимает значение 2 (PA-ENC-TIMESTAMP). Само значение `padata-value` содержит структуру `EncryptedData`:

```
EncryptedData ::= SEQUENCE {
    etype  [0] Int32, -- Тип шифрования (например, 23 для RC4, 18 для AES256)
    kvno   [1] UInt32 OPTIONAL,
    cipher [2] OCTET STRING -- Зашифрованная временная метка
}
```

Алгоритмы шифрования и сложность подбора

Тип шифрования (`etype`) определяет, насколько ресурсоемким будет процесс офлайн-взлома. В сетях Active Directory наиболее часто встречаются следующие алгоритмы:

- **RC4-HMAC (etype 23):** Устаревший, но все еще встречающийся алгоритм. Ключ шифрования — это просто NT-хэш пароля пользователя (MD4 от UTF-16LE пароля). Скорость перебора на современных GPU (например, RTX 4090) достигает десятков миллиардов паролей в секунду.

- **AES128-CTS-HMAC-SHA1-96 (etype 17) и AES256-CTS-HMAC-SHA1-96 (etype 18):** Современный стандарт. Процесс деривации ключа (String2Key) включает алгоритм PBKDF2 с 4096 итерациями, где в качестве "соли" используется конкатенация имени домена и имени пользователя (DOMAIN.COMusername). Это снижает скорость перебора в тысячи раз по сравнению с RC4, делая brute-force нецелесообразным и требуя использования качественных словарей и правил мутации (rule-based attacks).

Практика: Даже при использовании AES256 (etype 18), слабые пароли сервисных учетных записей или пароли, основанные на корпоративных паттернах (например, Company2025!), успешно взламываются словарными атаками. Наличие криптотекста — это уже половина успеха для Red Team.

Боевой сценарий: Практическая реализация AS-REQroasting

Процесс эксплуатации уязвимости состоит из четырех последовательных этапов. Ниже приведен детальный разбор действий атакующего.

Этап 1: Получение позиции Man-in-the-Middle (MITM)

Поскольку AS-REQroasting требует перехвата трафика между легитимным клиентом и контроллером домена, атакующему необходимо занять позицию "человек посередине". В плоских L2-сетях или слабо сегментированных VLAN это достигается классическими методами:

- **ARP Spoofing:** Отравление ARP-кэша шлюза и целевых рабочих станций.
- **DHCPv6 Spoofing (mitm6):** В сетях IPv4, где IPv6 включен по умолчанию (стандартное поведение Windows), атакующий отвечает на запросы DHCPv6, назначая себя в качестве DNS-сервера для IPv6. Это позволяет перенаправлять трафик аутентификации на машину злоумышленника.
- **ICMP Redirect:** Использование управляющих сообщений ICMP для изменения таблиц маршрутизации хостов.

Пример запуска атаки DHCPv6 Spoofing с использованием фреймворка mitm6:

```
# Запуск mitm6 для перехвата DNS-запросов в целевом домене corp.local
sudo mitm6 -d corp.local -i eth0
```

Параллельно запускается инструмент для маршрутизации и захвата трафика, например, Responder или просто tcpdump.

Этап 2: Захват трафика Kerberos AS-REQ

Находясь в позиции MITM, злоумышленник начинает дампит проходящий сетевой трафик. Цель — сохранить пакеты, направляющиеся на порт 88 (Kerberos) контроллера домена.

Для записи сырого трафика в формате PCAP используется tcpdump:

```
# Захват трафика на порту 88 и сохранение в файл
sudo tcpdump -i eth0 port 88 -w kerberos_capture.pcap
```

Если атакующий хочет сразу фильтровать трафик и видеть только пакеты AS-REQ с включенной преаутентификацией, можно использовать tshark (консольную версию Wireshark):

```
# Фильтрация AS-REQ (msg.type == 10) с наличием PA-ENC-TIMESTAMP (pdata.type == 2)
tshark -r kerberos_capture.pcap -Y "kerberos.msg.type == 10 and kerberos.padata.type
```

Ошибка: Начинающие пентестеры часто забывают настроить IP Forwarding на своей машине перед запуском ARP Spoofing. Это приводит к состоянию Denial of Service (DoS) для целевых машин, так как их трафик отбрасывается, а не пересылается на KDC. В результате легитимный AS-REQ не формируется, и атака срывается.

Этап 3: Экспорт зашифрованных временных меток

После того как трафик записан в PCAP-файл (или в процессе живого перехвата), необходимо извлечь саму криптограмму — зашифрованную временную метку из поля PA-ENC-TIMESTAMP. Ручной экспорт через графический интерфейс Wireshark возможен (путем копирования значения cipher как Hex Stream), однако в боевых условиях это неэффективно.

Для автоматизации процесса извлечения The Hacker Recipes и другие профильные ресурсы рекомендуют использовать специализированные парсеры, такие как **PCredz**. Этот инструмент способен на лету анализировать сетевой трафик или читать готовые дампы, автоматически извлекая хэши в форматах, готовых для взлома.

Пример использования PCredz для анализа сохраненного дампа:

```
# Запуск PCredz для анализа PCAP-файла и извлечения учетных данных
python3 Pcredz.py -f kerberos_capture.pcap
```

PCredz автоматически распознает пакеты Kerberos AS-REQ Pre-Auth (в частности, etype 23 — RC4-HMAC) и выведет на экран, а также сохранит в лог-файл строку, пригодную для передачи в криптоанализаторы. Если требуется написать

собственный скрипт, можно использовать библиотеку `scapy` или `pyshark` для Python, фильтруя слой Kerberos и извлекая нужные байты.

Этап 4: Офлайн-взлом зашифрованных временных меток

Полученные криптограммы передаются в инструменты для офлайн-перебора паролей. Здесь кроется важное техническое отличие от классического AS-REP `roasting`.

Важно: Для AS-REP `roasting` в Hashcat существует выделенный режим 18200 (Kerberos 5 AS-REP etype 23). Однако структура криптограммы AS-REQ (преаутентификации) иная. Поэтому форматы хэшей и режимы работы инструментов отличаются.

Для взлома AS-REQ `roasting` часто используется **John the Ripper (JtR)**, который имеет встроенную поддержку формата `krb5pa` (Kerberos 5 Pre-Auth). Если используется Hashcat, хэш необходимо привести к поддерживаемому формату или использовать кастомные модули.

Пример запуска атаки по словарю с использованием John the Ripper для извлеченного хэша преаутентификации:

```
# Запуск перебора паролей с использованием словаря rockyou.txt
john --format=krb5pa --wordlist=/usr/share/wordlists/rockyou.txt extracted_asreq_has
```

Практический опыт Red Team показывает, что при наличии слабых паролей (словарные слова, низкая энтропия, использование года или названия компании в пароле) скорость перебора на современных видеокартах позволяет получить plaintext-пароль за считанные часы или даже минуты. Полученный пароль валидируется и используется для дальнейшего продвижения по сети (Lateral Movement), повышения привилегий или запуска атак типа Pass-the-Ticket и S4U.

Сводный инструментарий для AS-REQ `roasting`

Для успешной реализации атаки применяется комбинация сетевых и криптографических утилит:

- **Сетевые снифферы и парсеры:**

- PCredz — основной инструмент для автоматического извлечения Kerberos AS-REQ Pre-Auth (etype 23) и других учетных данных (NTLM, HTTP Basic) из трафика.
- tcpdump / tshark / Wireshark — классические анализаторы для записи и глубокой инспекции пакетов.
- Bettercap / mitm6 / Responder — фреймворки для организации MITM-атак (ARP/DHCP/IPv6 spoofing).

- **Инструменты офлайн-подбора:**

- John the Ripper — поддержка формата krb5pa / krb5asrep.
- Hashcat — использование специализированных режимов при соответствующем форматировании криптограммы.

Оборона: Стратегии защиты от AS-REQroasting

Защита от AS-REQroasting требует комплексного подхода, так как атака эксплуатирует легитимный механизм протокола. Ведущие security-платформы (Semperis, Netwrix, JumpCloud) рассматривают эту угрозу как часть единого класса Kerberos-атак.

1. Сетевой уровень: Нейтрализация MITM-векторов

Поскольку фундаментом атаки является перехват трафика, главная задача сетевых инженеров — лишить злоумышленника возможности прослушивать чужие пакеты.

- **Сегментация сети:** Отказ от плоских L2-сетей. Жесткое разделение рабочих станций, серверов и контроллеров домена по разным VLAN с фильтрацией трафика на L3-уровне.
- **Защита от Spoofing-атак:** Включение на коммутаторах функций Dynamic ARP Inspection (DAI), DHCP Snooping, IP Source Guard и IPv6 RA Guard. Это предотвратит атаки типа ARP-poisoning и rogue DHCP/Router.
- **Шифрование на сетевом уровне:** Использование IPsec для защиты трафика между критичными узлами и контроллерами домена. Kerberos сам по себе не обеспечивает end-to-end шифрование транспортного уровня, поэтому компрометация L2-сегмента фатальна.

2. Усиление парольных политик

Даже если злоумышленник перехватил PA-ENC-TIMESTAMP, стойкий пароль сделает офлайн-взлом экономически нецелесообразным.

- Внедрение строгих политик длины (от 14 символов) и сложности паролей, особенно для сервисных (Managed Service Accounts) и административных учетных записей.
- Использование решений класса Password Filter / Password Protection (например, интеграция с Entra ID Password Protection или кастомные DLL-фильтры), которые блокируют использование скомпрометированных паролей из известных утечек.
- Регулярная ротация паролей и полный отказ от статических, бессрочных секретов.

3. Смещение доверия: PKINIT и MFA

Радикальный способ защиты — отказ от симметричной криптографии на базе пароля на этапе преаутентификации.

Рекомендации: Переход на Kerberos-преаутентификацию на основе сертификатов (PKINIT). В этом сценарии клиент использует асимметричную криптографию (закрытый ключ сертификата) для подписи запроса AS-REQ. Пароль больше не используется для генерации ключа шифрования временной метки, что делает словарные атаки невозможными.

Реализация PKINIT в Active Directory достигается через использование смарт-карт, виртуальных смарт-карт (Windows Hello for Business) или аппаратных FIDO-токенов. В таком случае, даже если пароль будет скомпрометирован иным путем, отсутствие второго фактора (сертификата) не позволит злоумышленнику получить TGT.

4. Мониторинг и обнаружение (Detection Engineering)

Детектирование AS-REQroasting — сложная задача для Blue Team. В отличие от AS-REP roasting, где KDC генерирует явные аномалии (массовые Event ID 4768 с Pre-Auth Type 0), при AS-REQroasting логи контроллера домена выглядят как обычная успешная аутентификация.

Упор должен делаться на сетевой мониторинг (NDR - Network Detection and Response):

- Обнаружение аномальных паттернов ARP-трафика (множественные ARP-ответы без запросов).
- Детектирование нелегитимных DHCP/DHCPv6 серверов в сети.
- Анализ логов IDS/IPS на предмет сигнатур MITM-инструментов (Responder, mitm6).

Место AS-REQroasting в современной модели угроз (2024–2026)

Аналитика от ведущих вендоров (Trellix, Picus, Netwrix) на 2024–2026 годы показывает, что атаки на Kerberos остаются в топе векторов компрометации AD. Хотя AS-REP roasting упоминается чаще из-за простоты эксплуатации (не требует MITM), AS-REQroasting рассматривается как более универсальный и опасный метод в сетях, где администраторы уже закрыли базовые мисконфигурации (включили преаутентификацию для всех аккаунтов).

Для **Red Team** эта техника остается незаменимой в сценариях локального присутствия (Assume Breach), когда инфраструктура хорошо защищена от прямых атак на AD, но сетевой уровень (L2) имеет изъяны. Даже если протоколы прикладного уровня защищены (SMB Signing включен, LDAP over TLS обязателен), перехват Kerberos-трафика дает шанс на получение plaintext-паролей.

Для **Blue Team** защита от AS-REQroasting является индикатором высокой зрелости инфраструктуры, так как требует внедрения PKINIT, жесткой сегментации сети и продвинутого NDR-мониторинга.

Вывод

AS-REQroasting — это элегантная и скрытная техника извлечения учетных данных, демонстрирующая, что даже корректно настроенные механизмы безопасности (Kerberos Pre-Authentication) могут быть обращены против самой системы при наличии уязвимостей на смежных уровнях (сетевой MITM). Понимание криптографической природы поля PA-ENC-TIMESTAMP и методов его извлечения критически важно для современных специалистов по информационной безопасности. Эффективное противодействие этой угрозе лежит не в плоскости настройки одного чекбокса в AD, а требует эшелонированной защиты: от L2-коммутаторов до внедрения смарт-карт и строгих парольных политик.

FAQ (Часто задаваемые вопросы)

1. В чем фундаментальное отличие AS-REQroasting от AS-REP roasting? AS-REQroasting нацелен на перехват запроса клиента (AS-REQ) и извлечение зашифрованной временной метки (PA-ENC-TIMESTAMP). Для этого требуется позиция MITM, но не нужны ошибки в настройках AD. AS-REP roasting нацелен на ответ сервера (AS-REP) и требует, чтобы у целевого аккаунта была отключена преаутентификация, но при этом MITM не нужен — атакующий сам запрашивает билет у KDC.

2. Можно ли провести AS-REQroasting без позиции Man-in-the-Middle? Нет. Злоумышленник должен иметь возможность пассивно прослушивать или активно

перехватывать трафик между легитимным клиентом (рабочей станцией) и контроллером домена (KDC), чтобы захватить пакет AS-REQ.

3. Какие алгоритмы шифрования используются для защиты PA-ENC-TIMESTAMP?

В зависимости от настроек домена и клиента, могут использоваться RC4-HMAC (etype 23), AES128-CTS-HMAC-SHA1-96 (etype 17) или AES256-CTS-HMAC-SHA1-96 (etype 18). RC4 взламывается крайне быстро, AES требует значительно больших вычислительных мощностей.

4. Поможет ли полное отключение RC4 в домене защитить от этой атаки?

Отключение RC4 значительно усложнит атаку, так как взлом AES256 требует огромных ресурсов. Однако это не является панацеей: если пользователь использует слабый, словарный пароль, криптограмма на базе AES все равно будет взломана с помощью rule-based атак на GPU.

5. Как обнаружить AS-REQroasting с помощью SIEM-системы?

Обнаружить саму кражу хэша через логи KDC (Windows Event Logs) практически невозможно, так как для контроллера домена это выглядит как легитимная попытка входа.

Детектирование должно строиться на выявлении сетевых аномалий (ARP/DHCP spoofing) с помощью NDR-решений и систем предотвращения вторжений (IDS).

6. Защищает ли многофакторная аутентификация (MFA) от извлечения PA-ENC-TIMESTAMP?

Если MFA реализована поверх стандартного парольного входа (как дополнительный шаг после Kerberos), хэш все равно можно извлечь и взломать.

Однако, если используется PKINIT (аутентификация по сертификатам/смарт-картам), пароль не используется для шифрования временной метки, что делает AS-REQroasting невозможным.

7. Какие инструменты лучше всего подходят для автоматического извлечения хэшей из трафика?

Наиболее популярным и эффективным инструментом является PCredz. Он умеет на лету парсить PCAP-файлы или живой трафик и автоматически извлекать хэши Kerberos AS-REQ Pre-Auth в формате, готовом для передачи в John the Ripper или Hashcat.

8. Почему атака AS-REQroasting остается актуальной в 2026 году?

Несмотря на развитие облачных технологий, большинство корпоративных сетей сохраняют on-premise Active Directory. Пока в сети присутствуют плоские L2-сегменты, уязвимые к MITM, и пользователи продолжают использовать пароли вместо беспарольной аутентификации (FIDO2/SmartCards), перехват и офлайн-взлом Kerberos-трафика будет оставаться рабочим вектором для Red Team.